

[03-01-2023: Security Incident Update and Recommended Actions](#)

Szablon analizy

1. Nazwa incydentu

LastPass Security Incident 2022, 2023

2. Organizacja i rok

LastPass 2022, 2023

3. Profil atakującego

cyberprzestępcy (unauthorized threat actor).

insider,

APT,

inny,

brak atakującego — awaria lub błąd operacyjny.

4. Wektor wejścia

- Incydent 1: skompromitowany laptop firmowy inżyniera oprogramowania lastpass
- Incydent 2: atakujący namierzył starszego inżyniera DevOps, wykorzystując podatność w oprogramowaniu firm trzecich do dostarczenia malware

allowing the unauthorized threat actor to gain access to a cloud-based development environment and steal source code, technical information, and certain LastPass internal system secrets (Inc #1)

The threat actor targeted a senior DevOps engineer by exploiting vulnerable third-party software. The threat actor leveraged the vulnerability to deliver malware, bypass existing controls, and ultimately gain unauthorized access to cloud backups (Inc #2)

5. Cel działania

- motywacja - nieznana; nie było kontaktu ani żądań okupu
- efekt: kradzież danych (exfiltration): kod źródłowy, sekrety, dane klientów i backupy skarbca haseł

To date, however, the identity of the threat actor and their motivation remains unknown. There has been no contact or demands made, and there has been no detected credible underground activity indicating that the threat actor is actively engaged in marketing or selling any information obtained during either incident.

Accessed data:

- cloud-based development and source code repositories
 - internal scripts from the repositories
 - internal documentation
- (inc #1)

- DevOps Secrets – restricted secrets that were used to gain access to our cloud-based backup storage
 - Cloud-based backup storage
 - Backup of LastPass MFA/Federation Database
- (inc #2)

6. Naruszone elementy CIA

poufność:

skradziono kod źródłowy, informacje techniczne, sekrety wewnętrzne LastPass oraz zaszyfrowane i niezaszyfrowane dane klientów

integralność:

N/A

Brak informacji o modyfikacji danych — atakujący tylko kopiował/wykradał

dostępność:

N/A

Brak wzmianki o przerwach w działaniu usługi

7. Cyber Kill Chain

Etap Co wydarzyło się w incydencie?

Reconnaissance

N/A

Weaponization

N/A

(wiadomo tylko, że wykorzystano podatność w oprogramowaniu third-party)

Delivery

atakujący dostarczył malware, wykorzystując podatną aplikację firm trzecich zainstalowaną na komputerze inżyniera DevOps

Exploitation

Wykorzystanie podatności third-party software do ominięcia kontroli bezpieczeństwa

Installation

Instalacja malware na stacji roboczej pracownika

Command & Control

N/A

Actions on Objectives

Incydent 1: kradzież kodu źródłowego z 14 z 200 repozytoriów oraz wewnętrznych sekretów.

Incydent 2: dostęp do backupów w chmurze zawierających dane konfiguracyjne, sekrety API, metadane klientów oraz kopie zapasowe wszystkich skarbów klientów, a także bazę MFA/federacji

dane skradzione w Incydencie 1 posłużyły do identyfikacji celu i zainicjowania Incydentu 2

Nie każdy etap musi być możliwy do potwierdzenia. Uczestnicy powinni zaznaczyć „brak danych”, zamiast zgadywać.

8. Co poszło nie tak po stronie obrońców?

- Prywatny laptop/stacja robocza inżyniera nie była wystarczająco odizolowana od środowiska produkcyjnego/deweloperskiego — kompromitacja pojedynczego endpointu dała dostęp do repozytoriów kodu
- Incydent 1 uznano za "zamknięty" bez pełnego zrozumienia, że wykradzione dane (sekrety, dokumentacja techniczna) mogą posłużyć jako punkt wyjścia do kolejnego ataku — brak pełnej analizy skutków ubocznych
- Podatne oprogramowanie firm trzecich na stacji roboczej starszego inżyniera DevOps nie zostało załatane/zabezpieczone na czas
- Sekrety DevOps (dające dostęp do backupów w chmurze) nie były dostatecznie odizolowane/rotowane — pojedynczy zestaw danych uwierzytelniających dał dostęp do całych backupów klientów
- Komunikacja kryzysowa: CEO przyznał, że komunikacja z klientami była zbyt rzadka i mało kompleksowa na przestrzeni całego procesu

9. Gdzie można było przerwać incydent?

- Na poziomie endpointu — segmentacja/hardening stacji roboczych inżynierów (EDR, ograniczenie uprawnień lokalnych) mogłoby zablokować dostarczenie malware przez podatność third-party
- Na poziomie patch management — aktualizacja/łatanie podatnego oprogramowania firm trzecich przed atakiem (Delivery/Exploitation)
- Po Incydencie 1 — pełny threat hunting i rotacja WSZYSTKICH sekretów (nie tylko "relevant") mogły uniemożliwić wykorzystanie skradzionych danych do zainicjowania Incydentu 2

10. Trzy rekomendacje bezpieczeństwa

- Zero Trust dla stacji roboczych uprzywilejowanych — inżynierowie z dostępem do środowisk produkcyjnych/backupowych powinni pracować na izolowanych urządzeniach + EDR
- Zasada least privilege (pojedynczy skompromitowany sekret nie powinien nigdy dawać dostępu do pełnych backupów wszystkich klientów)
- Threat hunting po każdym incydencie zamkniętym jako "closed" — przed formalnym zamknięciem incydentu należy zweryfikować, czy skradzione dane (nawet pozornie niekrytyczne, jak dokumentacja techniczna) nie mogą posłużyć jako wektor do kolejnego ataku (lekcja z Incydentu 1 → 2).